

05 - Database / Transactional Systems Denetimi

Olusturulma: 14 Nisan 2026 19:49 Kaynak: docs/audit Format: Tekil rapor

05 - Database / Transactional Systems Denetimi

Denetim tarihi: 2026-04-14 Kapsam: tablo semasi, migration disiplini, tarihsel veri guvenligi, tenancy, siparis/odeme iliskileri, urun/kategori/yazici eslemeleri, print job ve musteri verisi.

Son uygulama turunda guvenli ve uygulanabilir iyilestirmeler koda alindi: tarihsel snapshot kolonlari, snapshot backfill, indeks dostu tarih sorgulari, seed production guard'i, yeni kurulumlar icin CHECK constraint'leri ve raporlari snapshot verisine tasinmasi uygulandi.

Veri modeli ozeti

Uygulama SQLite uzerinde tek migration dosyasi ile calisiyor: [server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js). Model cok kiracili bir yapiya hazir: neredeyse tum ana tablolarda `business_id` var ve route'lar `req.businessId` ile scope uyguluyor.

Ana tablolar:

- `businesses`, `branches`, `roles`, `users`: tenant, sube ve kullanıcı yetki temeli.
- `dining_areas`, `tables`: masa ve salon modeli.
- `categories`, `products`, `product_portions`, `product_modifiers`, `product_combos`: canlı menu tanımları.
- `orders`, `order_items`, `payments`, `payment_allocations`: tarihsel işlem kaydı.
- `printers`, `printer_routing`, `print_jobs`: yazıcı tanımı, kategori-yazıcı eşlemesi ve job geçmişi.
- `customers`, `customer_phones`, `customer_addresses`, `call_logs`: müşteri ve Caller ID bağlamı.

Sema genel olarak pratik POS akisini tasiyor; ancak profesyonel urun kalitesi acisindan en onemli ayrim, "canli tanim verisi" ile "tarihsel islem verisi" arasinda tam olarak tamamlanmamis. Siparis kalemi urun adi/fiyati snapshot'liyor; fakat kategori, vergi, yazici hedefi ve bazi raporlar hala canli menu tanimlarina bakiyor.

Guclu yonler

1. Siparis satirinda temel urun snapshot'i var

`order_items` tablosu `product_id` ile canli urune bagli kalirken, `product_name`, `quantity`, `unit_price`, `modifiers`, `vat_rate`, `portion_id`, `portion_label` gibi islem anindaki kritik alanlari da sakliyor ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):217).

Etki: Urun adi veya fiyat degisse bile gecmis adisyonunda temel tutar ve urun adi korunuyor.

2. Urun ve kategori silme hard delete degil

Urun silme `DELETE` yerine `is_deleted = 1`, `is_active = 0` yapiyor ([server/routes/products.js](D:/dev/restoran-pos-v3/server/routes/products.js):380). Kategori silme de kategoriye pasife aliyor ve alt urunleri pasif/silinmis isaretliyor ([server/routes/categories.js](D:/dev/restoran-pos-v3/server/routes/categories.js):102).

Etki: Gecmis siparislerdeki `product_id` FK baglari hard delete ile kopmuyor.

3. Odeme idempotency icin veri modeli guclendirildi

Son backend hardening ile `payments` tablosuna `idempotency_key` ve `source` alanlari eklendi ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):250). Existing DB icin kolon ekleme ve unique index kurulumu migration icinde garantiye alindi ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):595).

Etki: Odeme tekrar istegi finansal kaydi iki kez olusturmayacak sekilde veri modelinde de destekleniyor.

4. Print job idempotency var

`print_jobs.idempotency_key` UNIQUE tanimli ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):301). Bu, mutfak/fis/paket etiketi job'larinda duplicate yazdirma riskini azaltan dogru bir karar.

5. Business scope icin temel indeksler mevcut

`users`, `tables`, `orders`, `products`, `categories`, `customers`, `payments`, `print_jobs` gibi ana tablolarda business veya iliski odakli indeksler var ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):343).

Tarihsel veri riskleri

P1 - Kategori bazli raporlar canli urun/kategori tanimina bagli

Kanit: Raporlarda kategori kirdirimi `order_items -> products -> categories` join'i ile hesaplaniyor ([server/routes/reports.js](D:/dev/restoran-pos-v3/server/routes/reports.js):43). `order_items` icinde `category_id` veya `category_name` snapshot'i yok ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):217).

Etki: Bir urun sonradan baska kategoriye tasinirse veya kategori yeniden adlandirilirsa, gecmis satislar bugunku kategoriye gore raporlanir. Bu restoran sahibi icin tarihsel ciro analizini bozabilir.

Kok neden: Urun snapshot'i var ama kategori snapshot'i yok.

Uygulandi: `order_items` icine `category_id_snapshot`, `category_name_snapshot`, `printer_target_snapshot` eklendi. Yeni siparislerde bu alanlar order create/add-items sirasinda dolduruluyor; mevcut kayitlar icin best-effort backfill calisiyor.

P1 - Yazici routing tarihsel olarak snapshot'lanmiyor

Kanit: Canli urun/kategori yazici hedefleri `products.printer_target` ve `categories.printer_target` alanlarindan geliyor ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):98, [server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):114). Siparis satirinda o anki yazici hedefi saklanmiyor.

Etki: Kategori veya urunun yazici hedefi degisirse, gecmis order item'dan tekrar mutfak/duzeltme job'u uretilirken bugunku routing ile tarihsel routing karisabilir.

Kok neden: Yazici hedefi canli tanim verisi olarak kalmis, order item transaction snapshot'ina alinmamis.

Uygulandi: `printer_target_snapshot` eklendi ve yeni siparis satirlarinda urun/kategori routing bilgisinden donduruluyor.

P2 - Vergi ve servis ucreti modeli tutar guvenligi icin yetersiz

Kanit: `orders` tablosunda `subtotal`, `discount_amount`, `discount_percent`, `service_charge`, `vat_total`, `grand_total` alanlari REAL olarak duruyor ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):199). `order_items.vat_rate` var ama create akisi `vat_rate` ve `vat_total` icin fiilen 0 yaziyor.

Etki: Gelecekte KDV, servis bedeli veya yuvarlama kurallari ciddiye alindiginda eski siparislerin hangi kural setiyle hesaplandigi anlasilmayabilir.

Kok neden: Fiyat hesaplama policy versiyonu ve para birimi/tutar minor unit modeli yok.

Oneri: V2 icin `currency`, `pricing_policy_version`, `subtotal_cents`, `grand_total_cents` gibi integer minor-unit modeline gecis planlanmalidir. Kisa vadede REAL kalacaksa tum hesaplar merkezi `round2` ile korunmalidir ve audit testleri artirilmalidir.

P2 - Kullanici, musteriler ve masa isimleri tarihsel belgelerde kismen canli okunuyor

Kanit: Orders `user_id`, `customer_id`, `table_id` FK sakliyor ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):195). Bazı query'ler kullanıcı/ masa/musteri adini canli join ile aliyor.

Etki: Garson adi, masa adi veya musteriler adi degisirse eski rapor ekranini yeni adla gorunebilir. Finansal tutar bozulmaz, ama tarihsel operasyon raporu zayıflar.

Uygulandi: `orders.table_name_snapshot`, `orders.user_name_snapshot`, `orders.customer_name_snapshot` alanlari eklendi ve mevcut kayıtlar icin backfill calistirildi. Musteriler sonradan siparise baglandiginda snapshot da guncelleniyor.

Silme / update riskleri

P1 - Foreign key davranislari ON DELETE politikasiz

Kanit: Çok sayıda FK `REFERENCES` ile tanımlı, fakat çoğu `ON DELETE` davranisi belirtmiyor. Örnek: `orders.table_id REFERENCES tables(id)`, `order_items.product_id REFERENCES products(id)`, `payments.order_id REFERENCES orders(id)` ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):195, [server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):220, [server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):241).

Etki: SQLite foreign key enforcement aktifse hard delete denemeleri patlar; aktif degilse orphan kayit riski dogar. Uygulama tarafında soft delete kullanimi bu riski azaltiyor ama sema seviyesinde politika net degil.

Kok neden: Referential action standardi belirlenmemis.

Oneri: Islem tablolarini icin hard delete yasaklanmalidir. Tanim tablolarında soft delete standart olmalidir. Gerçek `ON DELETE` davranisi yalnızca lookup/child cleanup icin bilincli kullanilmalidir; ornegin `product_portions` icin `ON DELETE CASCADE` zaten var ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):137).

P2 - Seed script production için tehlikeli davranış tasıyor

Kanit: Seed script baslarken çok sayıda tabloyu `DELETE FROM` ile temizliyor ([server/seeds/run.js] (D:/dev/restoran-pos-v3/server/seeds/run.js):12).

Etki: Yanlıs ortamda çalıştırılırsa canlı veri silinebilir.

Uygulandı: Seed script production ortamında `--force` verilmeden çalışmayacak şekilde güvenceye alındı.

P2 - Product/category update tarihsel raporları dolaylı etkiliyor

Kanit: Product update `name`, `price`, `category_id`, `printer_target` gibi canlı alanları değiştirebiliyor ([server/routes/products.js] (D:/dev/restoran-pos-v3/server/routes/products.js):249). Order item temel tutarı korusa da kategori/yazıcı hedefi snapshot'ı eksik.

Etki: Ürün adı ve fiyat geçmiş adisyonu bozmaz; kategori/yazıcı raporları bozabilir.

Uygulandı: Raporlardaki kategori kırılımı canlı kategori join'ı yerine order item snapshot alanlarını kullanacak şekilde tasındı.

Parasal alanlar

P1 - REAL para alanı uzun vadeli risk

Kanit: `products.price`, `orders.subtotal`, `orders.grand_total`, `payments.amount`, `payment_allocations.line_total` REAL olarak saklanıyor ([server/migrations/run.js] (D:/dev/restoran-pos-v3/server/migrations/run.js):110, [server/migrations/run.js] (D:/dev/restoran-pos-v3/server/migrations/run.js):199, [server/migrations/run.js] (D:/dev/restoran-pos-v3/server/migrations/run.js):246, [server/migrations/run.js] (D:/dev/restoran-pos-v3/server/migrations/run.js):264).

Etki: Küçük yuvarlama farkları, split payment ve gün sonu raporlarında birikebilir. Mevcut kod `round2` ile pratik tolerans uyguluyor; fakat database modeli profesyonel finansal sistem için ideal değil.

Oneri: V2 migration planında integer minor unit yani küçük bazlı alanlara geçilmeli. Kısa vadede yeni para alanları için CHECK constraint ve merkezi rounding testleri eklenmeli.

P2 - Tutar CHECK constraint'leri eksik

Kanit: `payments.amount REAL NOT NULL` ama `CHECK(amount > 0)` yok ([server/migrations/run.js] (D:/dev/restoran-pos-v3/server/migrations/run.js):246). `products.price REAL NOT NULL` ama DB seviyesinde positive constraint yok ([server/migrations/run.js] (D:/dev/restoran-pos-v3/server/migrations/run.js):110).

Etki: API validation atlanırsa negatif/sıfır tutar DB'ye girebilir.

Uygulandı: Yeni kurulum sırasında kritik numeric alanlara CHECK constraint eklendi. Mevcut SQLite tablolarında constraint eklemek tablo recreation gerektirdiği için canlı veri üzerinde zorlayıcı tablo yeniden oluşturma yapılmadı.

Performans ve indeks notları

Bu turda düşük riskli indeks iyileştirmeleri uygulandı:

- `tables.current_order_id`: masa kartı ve aktif order lookup'ları için ([server/migrations/run.js] (D:/dev/restoran-pos-v3/server/migrations/run.js):347).

- `orders(business_id, created_at)` : tarihsel siparis listesi ve rapor filtreleri için ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):352).
- `orders(business_id, status, created_at)` : aktif/kapanmis siparis listeleri için ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):353).
- `orders(business_id, closed_at)` : kapanis bazli raporlar için ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):354).
- `order_items(product_id)` : urun bazli analiz ve FK lookup için ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):356).
- `products(business_id, is_active, is_deleted)` : menu listesi için ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):359).
- `payments(business_id, created_at)` ve `payments(business_id, payment_type, created_at)` : ciro/odeme tipi raporlari için ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):366).
- `print_jobs(business_id, status, claimed_at, created_at)` : Bridge pending/unclaimed job sorgusu için; kolon migration'dan sonra kuruluyor ([server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js):580).

Not: Rapor sorgularında `date(created_at)` kullanimi indeks verimini sinirlayabilir. Daha profesyonel yaklasim, tarih araligini `created_at >= ? AND created_at < ?` ile sorgulamak veya ayrica `business_date` kolonu tutmaktir.

Veri modeli amatorluk belirtileri

1. Tek dosyada buyuyen migration

Tum sema ve sonradan eklenen migration yamalari tek [server/migrations/run.js](D:/dev/restoran-pos-v3/server/migrations/run.js) dosyasinda. `CREATE TABLE`, `ALTER TABLE`, backfill, tablo recreation ve seed benzeri default portion doldurma ayni dosyada.

Risk: Uretim migration sirasini izlemek, rollback planlamak ve hangi versiyonda hangi alanin geldigini anlamak zorlasiyor.

Oneri: Numarali migration dosyalari ve `schema_migrations` tablosu eklenmeli. `run.js` sadece migration runner olmalı.

2. Tarihsel snapshot standardi net degil

Order item urun adi/fiyati snapshot'liyor, ama kategori/yazici/masa/kullanici snapshot'i yok. Bu kısmi model "bazilari tarihsel, bazilari canlı" gibi okunuyor.

Oneri: Her order create sirasinda hangi alanlar tarihsel belge kabul ediliyor, tek policy dokumani ve testleri olmalı.

3. Seed script destructive ve ortam guard'i zayıf

Seed baslangicinda tablo temizleme var ([server/seeds/run.js](D:/dev/restoran-pos-v3/server/seeds/run.js):12). Bu demo için pratik, production için tehlikeli.

Oneri: `NODE_ENV=production` durumunda seed script calismamali; destructive mode için explicit flag istemeli.

4. Para modeli DB seviyesinde yeterince sert degil

API guard'lari artirildi, fakat DB constraint'leri hala finansal sistem kadar kati degil.

Oneri: Yeni numeric alanlar icin CHECK; uzun vadede integer cents.

Onerilen iyilestirmeler

Hemen / dusuk risk

1. Uygulandi: Rapor sorgularinda `date(column)` filtreleri indeks dostu aralik filtrelerine tasindi.
2. Uygulandi: Seed script'e production guard ve `--force` parametresi eklendi.
3. Uygulandi: Yeni kurulum semasinda kritik numeric alanlara CHECK constraint eklendi; API validation zaten korunuyor.
4. Korundu: Printer routing unique index temizleme davranisi migration akisi icinde kaldı.

Bu hafta / orta risk

1. Uygulandi: `order_items` icine kategori ve yazici hedef snapshot alanlari eklendi.
2. Uygulandi: Order create/add-items sirasinda kategori/yazici snapshot dolduruluyor.
3. Uygulandi: Raporlardaki kategori breakdown snapshot alanlarına tasindi.
4. Kismen uygulandi: Seed script production guard ile guvenceye alindi; non-destructive setup modu ayri urunlestirme adimi olarak duruyor.

Sonraki faz / yuksek dikkat

1. Kismen uygulandi: Para alanlari icin yeni kurulumlarda CHECK constraint ve API validation sertlestirildi. Tam integer minor unit gecisi geriye donuk veri uyumlulugu gerektirdigi icin ayri kontrollu migration olarak kalmali.
2. Kalmali: Migration sistemini numarali migration runner'a tasima ayri refactor olarak duruyor.
3. Kalmali: Soft delete ve referential action politikasini domain dokumani ve DB constraint stratejisiyle netlestirme halen gerekli.
4. Kismen uygulandi: Tarihsel belge modeli snapshot alanlariyla guclendirildi; tam immutable fiscal snapshot sonraki fazda ele alinmali.

Uygulanmis duzeltmeler

Uygulanan duzeltmeler:

- Masa aktif siparis lookup indeksi.
- Order tarih/status/closed_at indeksleri.
- Order item product lookup indeksi.
- Order item kategori snapshot indeksi.
- Product active/deleted menu filtre indeksi.
- Payment tarih ve payment type rapor indeksleri.
- Print job bridge claim/pending indeksi.
- Order item kategori/yazici snapshot kolonlari ve backfill.

- Order header masa/musteri/kullanici snapshot kolonlari ve backfill.
- Order create/add-items akisini snapshot yazacak sekilde guncelleme.
- Gunluk kategori raporunu canli kategori yerine tarihsel snapshot verisine tasima.
- Rapor ve odeme ozeti tarih filtrelerini indeks dostu aralik sorgularina tasima.
- Seed script production guard'i.
- Yeni kurulum semasinda para/adet alanlari icin CHECK constraint'leri.

Canli veritabaninda migration basariyla calisti; 164 `order_items` satiri ve 91 `orders` satiri icin best-effort snapshot backfill uygulandi.

Son karar

Veri modeli restoran POS icin temel operasyonu tasiyor ve son uygulamalarla tarihsel raporlama guvenligi belirgin sekilde iyilesti. Kategori/yazici hedef snapshot'i artik korunuyor. Kalan ana teknik borclar: para alanlarinin REAL olarak tutulmasi, migration sisteminin tek dosyada buyumesi ve tam immutable fiscal snapshot modelinin henuz bulunmaması.